Fase 7 | Matriz RACI

Caso C05 - PagoClaro Fintech S.A.S. | Asignación de responsabilidades

Matriz para las actividades de implantación y operación inicial de SOC N1. R ejecuta; A responde por la aprobación final (solo uno por actividad); C aporta criterio técnico; I recibe información.

1. Roles

ID	Rol	Alcance
GER	Gerencia / patrocinador	Autoriza CAPEX, OPEX y paso a producción
LID	Líder del proyecto y responsable SOC	Aprueba arquitectura técnica y estándares del SOC
N1	Analista SOC Nivel 1	Monitorea, filtra alertas, documenta y contiene dentro de facultades
N2	Soporte SOC Nivel 2	Investiga incidentes complejos y dirige acciones de alto impacto
TI	Administrador de TI	Opera sistemas, despliega agentes, ejecuta cambios aprobados
NGFW	Proveedor / integrador perimetral	Suministro, configuración y soporte firewall
EDR	Proveedor / integrador EDR	Acompañamiento a licencias, configuración y despliegue

2. Matriz de responsabilidades

Actividad	GER	LID	N1	N2	TI	NGFW	EDR
Aprobar alcance, autorizaciones y límites	A	R	I	I	C	–	–
Diseñar red, segmentación y VPN	I	A	C	C	R	C	–
Dimensionar Wazuh, infraestructura y registros	I	A	C	C	R	–	–
Instalar y validar Wazuh manager y agentes	I	A	C	C	R	–	–
Implementar FIM, CVE, SCA, decoders y paneles	I	A	R	C	R	–	–
Desplegar Kaspersky y 20 agentes	I	A	C	C	R	–	C
Definir excepciones EDR, alertas y cambios	I	A	R	C	C	–	C
Configurar GLPI, respaldos y restauración	I	A	C	C	R	–	–
Seleccionar, cotizar y aprobar NGFW	A	R	C	C	C	C	–
Instalar NGFW, VLAN, IPS y VPN site-to-site	I	A	C	C	R	R	–
Definir playbooks, escalamiento, SLAs y KPIs	I	A	R	C	C	–	–
Aplicar contención de alto impacto	I	A	C	R	R	C	C
Capacitar analistas y ejecutar piloto	I	A	R	C	C	–	C
Controlar presupuesto / TCO y cotizaciones	A	R	C	C	C	C	C
Autorizar puesta en producción y reporte final	A	R	C	C	C	I	I

3. Reglas de decisión y escalamiento

• Cada actividad tiene un único A. El Líder aprueba procedimientos técnicos; Gerencia aprueba presupuesto, alcance y paso a producción.

• N1 no administra cuentas privilegiadas ni reinstala, borra evidencia o modifica reglas unilateralmente; estas tareas se asignan a TI o N2 con la aprobación correspondiente.

• El integrador NGFW no autoriza por sí solo cambios a la VPN hacia el núcleo transaccional. TI implementa después de la aprobación del Líder.

• Las reuniones de control son semanales (semanas 1-8); el inventario de riesgos y las decisiones de compra se archivan en el repositorio del proyecto.

4. Aprobaciones de proyectos que involucran datos financieros

Las modificaciones de flujos hacia base de datos y API de pagos requieren autorización del Líder y revisión del administrador TI/N2. Gerencia aprueba comunicaciones externas y presupuesto, conforme al esquema académico C05.